

ALI Daliani
KHASSER Yanis
EL HAMIOUI Yassine
TUNAY Ilyas

Cahier des charges

Honey-V

1. Objectifs du projet

Objectifs du projet

L'objectif est de passer d'une sécurité passive à une sécurité active.

- **La Dissuasion et observation** : Capturer les outils, les trafics et les méthodes des attaquants dans un environnement contrôlé.
- **La Réduction des faux positifs** : Le fait d'avoir un Honeynet dans une infrastructure permet de réduire les faux positifs, toute interaction avec le Honeynet est par définition suspecte.
- **Les Réponses Automatisées** : L'utilisation d'un SIEM et SOAR pour la remonter des logs et bloquer l'attaquant avant qu'il ne touche la production et primordial pour l'infrastructure.

Le besoin :

De nos jours, les entreprises ont du mal à détecter les mouvements latéraux et les menaces persistantes. Ce projet répond au besoin de détecter une intrusion dès la phase de reconnaissance grâce aux Honeynets.

2. Approche fonctionnelle et technique

Nous allons mettre en place un Honeywall entre le réseau de production et le Honeynet afin d'isoler les 2 zones distinctes. En ce qui concerne les honeypots, nous allons en choisir 3 :

- **Cowrie** : Honeypot SSH/Telnet pour capturer les attaques par force brute et les binaires déposés.
- **Dionaea** : Capture de malwares via des protocoles comme SMB
- **Honeypot de Haute Interaction (Active Directory)** : Simulation d'un contrôleur de domaine Windows Server 2022 pour piéger les scans LDAP et Kerberos.

A l'intérieur du Honeypot AD nous allons ajouter des vulnérabilité contrôlé : les protocoles LLMNR et NetBIOS (NBT-NS) seront laissés activés pour intercepter des attaques type *Man-in-the-Middle*, des sessions RDP "Oubliées" une session administrateur (factice) ouverte, un attaquant pourra tenter d'extraire les identifiants en clair directement de la mémoire. Ensuite nous ajouterons différent type de Honeytokens (ressources numériques) permettant de leurrer l'attaquant. Par exemple, des comptes utilisateurs "Honey-Admins" dont la simple connexion déclenche une alerte critique , des documents Office piégés, des fichiers Word ou Excel qui lorsqu'ils sont ouverts, effectuent une requête vers un serveur de contrôle, révélant l'adresse IP de l'attaquant, ça peut aussi être des fichiers de configuration placés sur un partage réseau, si il sont ouvert on reçoit une alerte critique.

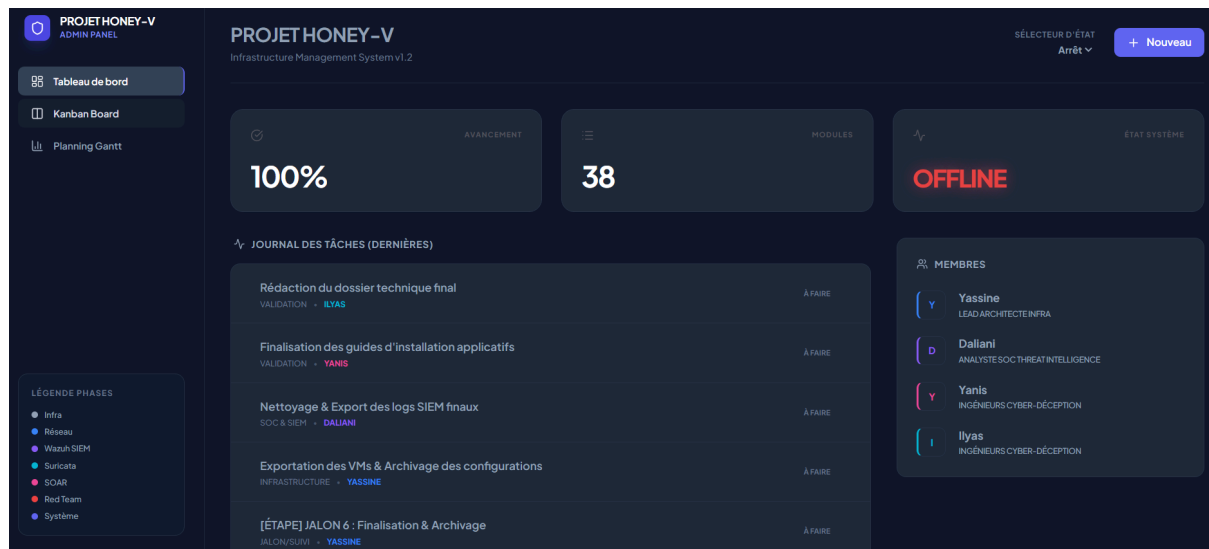
L'implémentation d'un SIEM (Wazuh) permet d'injecter les logs du Honeywall et des agents installés sur les honeypots. Nous allons ajouter des règles de détection concernant les intrusions, de plus spécifiques à la déception (honeynet).

L'implémentation d'un SOAR (TheHive) permet d'automatiser et générer des tickets d'incident afin de traiter les différentes alertes.

Grâce au remonter et aux différents tickets nous pourrons faire de la réponse active c-a-d créé un script de bannissement automatique de l'IP source sur le Firewall (pfSense).

3. Rétroplanning

La gestion du projet HONEY-V s'appuie sur la méthodologie Scrumban (hybridation entre Scrum et Kanban). Cette approche agile nous permet de maintenir un tableau de bord visuel de l'avancement des tâches tout en respectant des itérations fixes alignées sur les jalons d'évaluation (Sprints).



3.1. Répartition des Responsabilités

- Lead Architecte Infrastructure (Yassine EL HAMIOUI) : Déploiement du socle Proxmox (VMs, ISOs) et sécurisation des flux via le Honeywall / pfSense.
- Analyste Threat Intelligence (ALI Daliani) : Administration de la stack SOC et configuration des politiques de détection.
- Ingénieurs Cyber-Déception (Yanis KHASSER & Ilyas TUNAY) : Implémentation des services leurres (AD, Honeywall, Cowrie, Dionaea, Conpot, Honey-tokens) et développement des scripts de réponse active.

3.2. Jalons de Livraison (Mars - Juillet 2026)

Jalon 0 : Initialisation (02/03 – 06/03) : Cadrage technique, validation du schéma réseau et provisionnement de l'environnement de virtualisation Proxmox.

Jalon 2 : Implémentation de la Déception (30/03 – 30/04) : Promotion du domaine Windows Server 2022 factice, activation des vulnérabilités volontaires (LLMNR, Kerberoasting) et dispersion des ressources leurres (Honey-tokens).

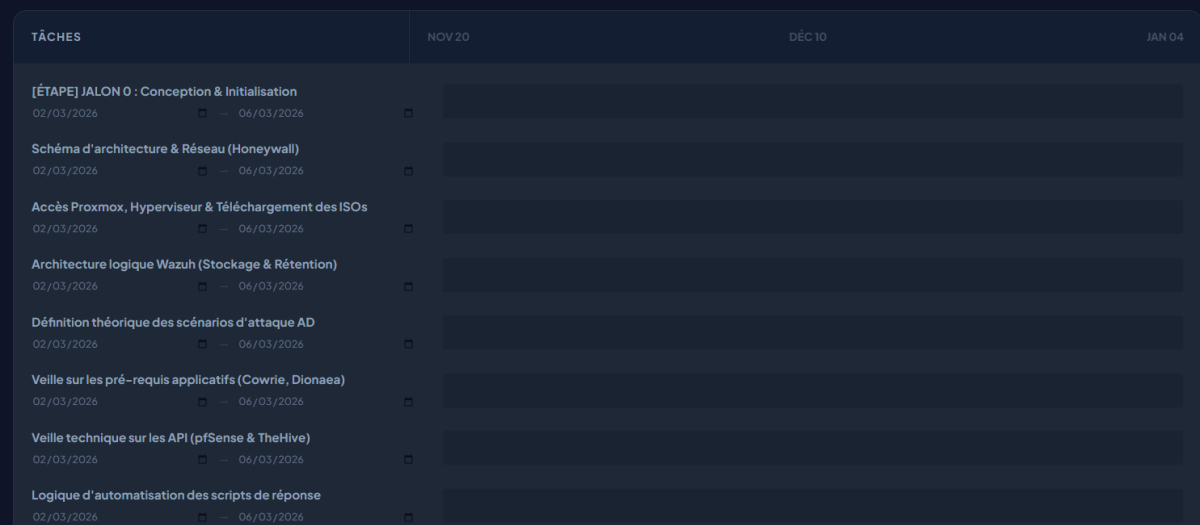
Jalon 3 : Automatisation & SOAR (30/04 – 15/05) : Déploiement de TheHive, interfaçage avec Wazuh et écriture des scripts de bannissement automatique d'IP via API.

Jalon 4 : Recettage & Red Teaming (15/05 – 30/05) : Simulation d'attaques réelles (mouvements latéraux, énumération) pour valider la chaîne de détection et la réponse active.

Jalon 5 : Dry-Run & État Final (30/05 – 15/06) : Audit de stabilité de l'infrastructure, gel des configurations et production de la vidéo de démonstration (POC).

Jalon 6 : Clôture & Rendu (15/06 – 10/07) : Archivage des données, exportation des sauvegardes finales et remise des dossiers techniques complets.

TIMELINE PROJET



4. Analyse de l'état de l'art

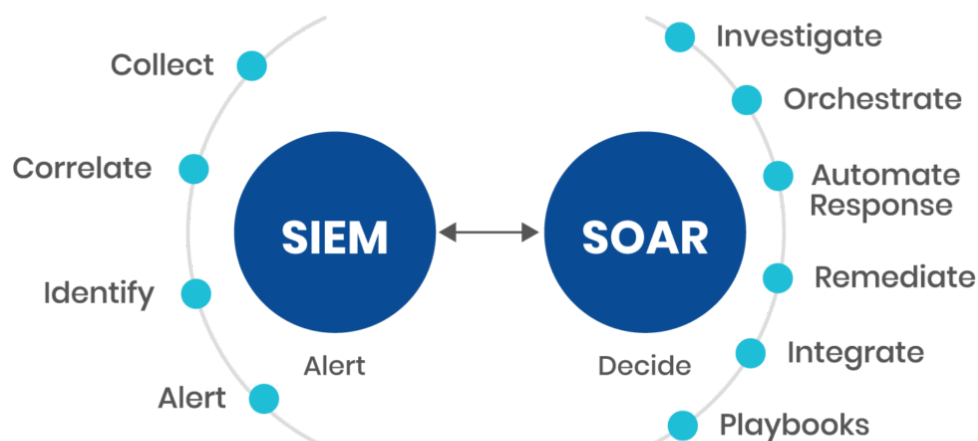
Pour mener à bien notre projet, nous allons mettre en place une infrastructure complète, ce qui comprend un réseau de production dans une zone démilitarisée. Un Firewall sera relié à la zone de production et à un Honeywall (agit comme un pont transparent pour ralentir l'attaquant sans qu'il ne se doute d'être observé) qui permettra "d'isoler" le Honeynet (un ensemble de Honeypots), les honeypots dites "pot de miel" sont des leurres permettant d'attirer les personnes malveillantes. Parmi les honeypots nous allons choisir des honeypots de haute et moyenne interaction et y inclure des Honeytokens (fichiers leurres). Les différents flux remonteront dans un SIEM où il y aura de la corrélation et différentes règles de détection. Et pour finir le SOAR générera des tickets d'incident afin de traiter les alertes et pouvoir blacklister les IOC.

L'évolution des menaces modernes montre que les solutions telles que les Firewalls et les antivirus classiques sont contournés par des attaques ciblées. La Cyber-Déception (stratégie pour attirer les cybercriminels) s'impose comme une couche de défense supplémentaire.

Honeypot Basse Interaction	Honeypot Moyenne Interaction	Honeypot Haute Interaction
 Objectif : Détection basique	 Objectif : Analyse et leurre partiel	 Objectif : Étude approfondie
 Niveau de Risque : Faible	 Niveau de Risque : Modéré	 Niveau de Risque : Élevé
 Complexité : Basse	 Complexité : Moyenne	 Complexité : Élevée

Les différents Honeypots

SIEM, SOAR: How can they add up?



A SOAR enhances the connection between tools used to enrich the flows of data ingested by the SIEM. It then triggers a set of playbooks to handle incidents, from detection to response.